

Lean Technologies

Information Security Policy

Approving Authority	Group Risk and Compliance Committee
Last review date	February 2025
Approval Date	March 2025
Advisor Chair	Chief Legal Officer
Next Scheduled Review	February 2026
Review Frequency	Yearly
Description	This documents the information security policy and objectives of Lean Tech in accordance with the requirements of Clause 5.2 of the ISO 27001 standard and SAMA CSF

Contents

1. Introduction	3
1.1 Cybersecurity Definition	3
2. Information Security Policy Scope	3
3. Information Security Management System Objectives and Responsibilities	4
4. Board Statement in support for CyberSecurity	4
6. Cyber Security Requirements	4
7. Referenced Lean Cyber Security Policies, Standards and Processes	5
8.. Cyber Security Requirements	5
8.1. Information Classification	5
8.2. Information Protection and Risk Appetite	5
8.3. Ownership of Information Assets	5
8.4. Cybersecurity Risk Assessments	6
8.5. Cybersecurity Awareness Program	6
8.6. Compliance with Regulatory and Contractual Obligations	6
8.7. Reporting Cybersecurity Breaches and Weaknesses	6
8.8. Cybersecurity in Business Continuity Management (BCM)	6
9. Security in the Project Management	6
10. Communication	7

1. Introduction

This policy defines Lean's requirements and related responsibilities, minimum standards, and process requirements for Information Security where applicable and appropriate within the defined scope. As a component of Lean Tech's Information Security Management System (ISMS), the policy is intended to ensure operational and information security-related risks are effectively managed. It seeks to achieve and maintain appropriate protection of organizational information and technology assets in accordance with the ISO 27001 standard controls for Information Security and SAMA Cyber Security Framework.

1.1 Cybersecurity Definition

Cybersecurity refers to the comprehensive set of measures, practices, and technologies designed to safeguard computer systems, networks, data, and digital assets from unauthorized access, disruptions, and malicious activities. It encompasses the protection of information technology infrastructure, the confidentiality and integrity of sensitive data, and the assurance of continuous, secure operations.

Cybersecurity aims to mitigate the risks associated with cyber threats, including cyberattacks, data breaches, and other forms of malicious exploitation, by implementing proactive strategies, robust controls, and ongoing vigilance. The goal of cybersecurity within our organization is to foster a resilient and secure digital environment, ensuring the confidentiality, integrity, and availability of critical information assets while maintaining compliance with relevant regulations and standards.

2. Information Security Policy Scope

Lean's ability to maintain high reputation, thus continuing to acquire and retain clients, depends on the highest standards of professionalism and integrity. It is paramount that these standards include the security of information, systems, and assets regardless of whether these assets are owned and controlled by Lean or provided by and processed on behalf of Lean clients.

It is Lean's policy to ensure that:

- Lean will seek to protect itself, its clients, as well as its ability to service its clients, from security threats to its business and operations.
- An ISMS is operated to meet the needs of Lean, its clients and other interested parties.
- These needs and objectives are derived from various sources such as client requirements, legislation, applicable regulations for all locations where Lean operates : UAE, UK, KSA. Lean's business strategy, response to emerging threats, and general security best practices.
- Information security objectives are approved and regularly reviewed by the Group Risk and Compliance Committee, Co-Founders and other senior staff across the organization.
- Lean's ISMS is appropriately resourced, regularly reviewed, and continuously improved.

3. Information Security Management System Objectives and Responsibilities

The ISMS objectives of Lean Tech are:

- To ensure Lean Tech's information is protected from unauthorized access.
- Confidentiality of all information is assured.

- Integrity of information is maintained.
- Availability of information is ensured.
- Secure infrastructure and network services.
- A framework is developed for identifying and mitigating risks to information assets by implementing controls and monitoring effectiveness.
- Regulatory, contractual and legislative requirements are met : ISO 27001, SAMA CSF, NCA frameworks, KSA OB requirements.
- Business continuity plans are produced, maintained and tested.
- Information security training will be available to all employees and relevant third parties.
- Adequate resources are deployed to implement, maintain and continuously improve an effective information security programme.

4. Board Statement in support for CyberSecurity

The Board of Directors hereby expresses its unequivocal commitment to advancing and supporting the cybersecurity objectives of Lean Technologies. Recognizing the critical importance of information security in today's digital landscape, we pledge to allocate the requisite resources, endorse a proactive cybersecurity culture, and provide strategic oversight to fortify the organization against evolving cyber threats. This commitment is integral to upholding the confidentiality, integrity, and availability of our digital assets and maintaining the trust of our stakeholders."

6. Cyber Security Requirements

- Establish and maintain a continuous risk assessment framework to identify, evaluate, and mitigate evolving cybersecurity threats and vulnerabilities.
- Information is classified in a way that indicates its importance to Lean. Different security mechanisms to safeguard information are applied, based on data sensitivity levels.
- Establish a holistic security governance model that integrates cybersecurity policies seamlessly with overall organizational governance, ensuring alignment with strategic objectives.
- Information is protected in terms of cyber security requirements, in line with the risk appetite. Risk appetite is reviewed on a recurrent basis. Owners are appointed for all information assets;
- Adopt a zero-trust network architecture, treating every user, device, and network segment as untrusted, and implement strict access controls based on continuous verification
- Cyber security risk assessments are conducted for information assets;
- Cultivate a sustainable cybersecurity culture by embedding security into the organizational DNA, promoting accountability, and fostering a sense of shared responsibility for cybersecurity.
- Develop and track quantifiable cybersecurity metrics aligned with organizational goals to measure the effectiveness of security controls and demonstrate return on investment.
- Compliance with regulatory and contractual obligations are being met;
- Cyber security breaches and suspected cyber security weaknesses are reported;
- Cyber security is reflected in business continuity management and Disaster Recovery.

7. Referenced Lean Cyber Security Policies, Standards and Processes

Lean Information Security Policy considered as input for other corporate policies and supported, where required, by detailed security standards and processes

- Identity and Access Management Policy

- Password Standard
- Security Governance and Strategy
- Security Operations
- Secure Software Development Process
- Physical Security Policy
- Infrastructure Security Standard
- Cloud Security Standard
- Security event management Standard
- Incident Response Process
- Cryptography Standard
- BCP and DR Standard and Processes
- Auditing, logging, monitoring Standard
- Security awareness process
- Endpoint protection standard
- HR Security policy
- IT Security policy
- 3rd party supplier management policy
- Data protection and information classification standard and processes
- Risk Management Framework and Risk Appetite

8.. Cyber Security Requirements

8.1. Information Classification

All information within Lean Technologies must be classified based on its importance and sensitivity to the organization. Information will be categorized into Public, Confidential, Restricted, and Highly Confidential(sensitive Personal Data as per PDPL), ensuring that appropriate protection measures are applied in line with the classification. See Lean Data Classification Policy.

8.2. Information Protection and Risk Appetite

Information must be protected in accordance with the organization's risk appetite. The Risk and Compliance Committee will review and approve the risk tolerance levels annually, ensuring that cybersecurity controls and safeguards are commensurate with the criticality of information assets and potential impacts of data breaches. See Lean Risk appetite

8.3. Ownership of Information Assets

Each information asset must have an appointed owner who is responsible for ensuring that the appropriate security controls, risk assessments, and incident response plans are in place. The CISO will maintain a comprehensive inventory of all information assets and their respective owners.

8.4. Cybersecurity Risk Assessments

Cybersecurity risk assessments will be conducted periodically on all information assets, particularly those classified as Confidential or higher. These assessments will be conducted in line with SAMA's Cybersecurity Framework and will evaluate the potential threats, vulnerabilities, and the impact of security breaches on the organization. See Lean Risk Assessment framework.

8.5. Cybersecurity Awareness Program

Lean Technologies will implement an ongoing Cybersecurity Awareness Program aimed at educating all employees, contractors, and third-party partners about their roles and responsibilities in safeguarding

information. The program will cover topics such as phishing awareness, secure password practices, and incident reporting. All employees are required to undergo annual cybersecurity training to remain updated on emerging threats.

8.6. Compliance with Regulatory and Contractual Obligations

All cybersecurity processes and policies must ensure compliance with regulatory frameworks including:

- SAMA Cybersecurity Framework (CSF), CRFR and MVC.
- KSA Personal Data Protection Law (PDPL)
- ISO/IEC 27001 and other relevant international standards Lean will undergo periodic audits to ensure continued compliance with these regulations, with findings reported to the Risk and Compliance Committee.
- Alignment with NCA security standards.

8.7. Reporting Cybersecurity Breaches and Weaknesses

All employees, contractors, and third parties must report suspected cybersecurity incidents or weaknesses to the security team immediately.. Lean Technologies maintains a defined incident response process, ensuring that breaches are swiftly detected, contained, and reported in compliance with SAMA and KSA PDPL requirements. The CISO will notify relevant authorities and stakeholders in the event of major incidents as required by law. See Lean Product Incident Response Process.

8.8. Cybersecurity in Business Continuity Management (BCM)

Cybersecurity is an integral part of Business Continuity Management (BCM) and Disaster Recovery (DR). In alignment with ISO 22301, the organization's BCP/DR plan will include procedures to ensure the continued security of information assets during and after a disruption. Cybersecurity incidents, including DDoS attacks and data breaches, will be considered in disaster recovery planning to minimize operational downtime and data loss.

9. Security in the Project Management

All organizational projects must integrate information security at every phase, from initiation to closure. Security requirements must be identified, documented, and addressed during project planning, with risk assessments conducted to mitigate potential threats. Project deliverables and processes must comply with the organization's Secure Development Lifecycle (SDLC), ISO 27001 standards, and applicable legal or regulatory requirements. Further more all security gates are mentioned in Lean Change and Release Management process (CRM). Testing for vulnerabilities must be performed before deployment, and security controls monitored throughout the project lifecycle.

Product Managers are responsible for embedding security into project activities, while a designated Security Advisor provides oversight and ensures adherence to security policies.

10. Communication

Lean Tech shall ensure that its Information Security Policy is effectively communicated to all relevant stakeholders, including employees, contractors, and third-party service providers who interact with the company's systems and data. This policy will be disseminated through official communication channels, including email notifications, security briefings, and the company's designated security awareness platform, Wizer. All employees are required to review and acknowledge their understanding of the policy upon onboarding and after any significant updates. Regular awareness sessions and training will be conducted to reinforce adherence to security principles and compliance requirements.